

Web and Cloud Discovery and Enumeration

CompTIA PenTest+ (PT0-003)

Domain:

- 2.0: Reconnaissance and Enumeration

Objectives:

- 2.1: Given a scenario, apply information gathering techniques.
- 2.2: Given a scenario, apply enumeration techniques.

Video Overview

This video helps you gain a foundational understanding of web and cloud discovery and enumeration. This is an important skill set for aspiring penetration testers, as understanding how to gather information about web applications and cloud services is a key part of identifying vulnerabilities. The concepts and tools covered in this video are relevant for the CompTIA PenTest+ certification exam and practical for a career in IT.

Key Topics Covered

- **Domain and Subdomain Brute Forcing:** Identifying hidden assets by enumerating DNS records, using tools like Nmap (with `dns-brute.nse`), Fierce, DNSmap, Sublist3r, and The Harvester.
- **Web Application Firewall (WAF) Enumeration:** Determining the presence and understanding the rules and behaviors of a WAF to inform testing strategies.
- **Site Crawling:** Mapping out a website's structure, including directories and their contents, typically using automated tools like OWASP ZAP and Burp Suite.
- **Web Scraping:** Using automated tools to extract specific information from websites.
- **Directory Fuzzing:** Systematically guessing for hidden or obscure directories that may contain valuable information, with tools such as Gobuster and Dirb.

- **Token Analysis:** Investigating the scope, issuing process, and revocation of tokens used for authorization and access in web applications.
- **Web Traffic Analysis:** Monitoring network traffic to gather information about credentials and tokens, including sniffing web traffic.
- **Cloud Asset Discovery:** Identifying how targets utilize cloud providers (AWS, Azure, GCP) and their services (e.g., S3 buckets), often relying on automation with tools like Amass and Cloud-enum.

Student Notes Section